

CYBERSNOVA



PROJECT REPORT

Prepared by
NAMRATA RAVINDRA PAWAR.

Field	Details
Full Name	Namrata Ravindra Pawar
Registration Number	CSN-SP-2026-155
Internship Domain	Cyber Security
Duration	1 month
Start Date	1 Sept 2026
End Date	30 Sept 2026
Mode	30 Sept 2026
Assigned Mentor	Internship Coordinator

Level 1=Beginner Level

PROJECT 4 — BASIC WEB VULNERABILITY ASSESSMENT

2. Objective

The objective of this project was to perform a basic security assessment of an intentionally vulnerable web application using authorized security-testing tools.

The assessment focused on identifying common web security weaknesses, reviewing HTTP response headers and cookies, identifying technology information disclosed by the server, and analyzing the application's login page using Burp Suite.

The testing was performed only against the authorized target:

<http://testasp.vulnweb.com/>

3. Target

<http://testasp.vulnweb.com/>

4. Tools Used

- Tool Versions
- Nikto: 2.6.0
- Burp Suite Community Edition: 2026.3.2
- cURL: Installed on Kali Linux

Scope and Target

- ***Scope:***

The assessment was limited to the authorized vulnerable web application provided for the internship.

- ***Target :*** testasp.vulnweb.com

- Protocol: HTTP
- Port: 80
- Server: Microsoft-IIS/8.5
- Application Technology: ASP.NET

The assessment included:

- Web server reconnaissance
- HTTP header analysis
- Cookie security analysis
- Technology/version disclosure analysis
- Basic HTTP method testing
- Login page analysis using Burp Suite

No unauthorized systems were tested.

Methodology & Implementation

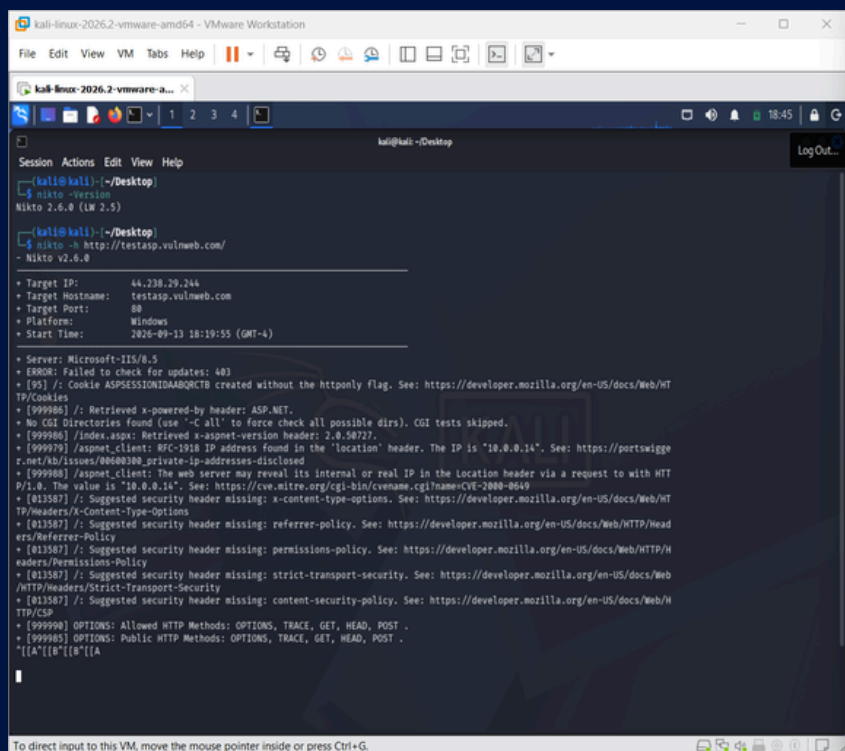
- **Web Server Scanning Using Nikto:**

Nikto was used to perform an initial security assessment of the authorized web application.

- **command:** `nikto -h http://testasp.vulnweb.com/`

The scan identified several server configuration and information-disclosure observations, which were subsequently reviewed and manually verified using cURL and Burp Suite.

- **Target:** testasp.vulnweb.com
- **Port:** 80
- **Web Server:** Microsoft-IIS/8.5



```
kali@kali:~/Desktop
$ nikto -h http://testasp.vulnweb.com/
Nikto v2.6.0

+ Target IP: 44.238.29.244
+ Target Hostname: testasp.vulnweb.com
+ Target Port: 80
+ Platform: Windows
+ Start Time: 2026-09-13 18:19:55 (GMT-4)

+ Server: Microsoft-IIS/8.5
+ ERROR: Failed to check for updates: 403
+ [90] /: Cookie ASPSESSIONIDABQRCB created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ [999986] /: Retrieved x-powered-by header: ASP.NET.
+ No CGI Directories found (use "-C all" to force check all possible dirs). CGI tests skipped.
+ [999986] /index.aspx: Retrieved x-aspnet-version header: 2.0.50727.
+ [999979] /aspnet_client: RFC-1918 IP address found in the 'location' header. The IP is "10.0.0.14". See: https://portswigger.net/kb/issues/00600300_private-ip-addresses-disclosed
+ [999988] /aspnet_client: The web server may reveal its internal or real IP in the Location header via a request to with HTTP/1.0. The value is "10.0.0.14". See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2000-0649
+ [813507] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/headers/X-Content-Type-Options
+ [813507] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/headers/Referrer-Policy
+ [813507] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/headers/Permissions-Policy
+ [813507] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/headers/Strict-Transport-Security
+ [813507] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [999990] OPTIONS: Allowed HTTP Methods: OPTIONS, TRACE, GET, HEAD, POST .
+ [999985] OPTIONS: Public HTTP Methods: OPTIONS, TRACE, GET, HEAD, POST .
+ ["[A][B][E][I]A
```

Figure 1 — Nikto Scan Results

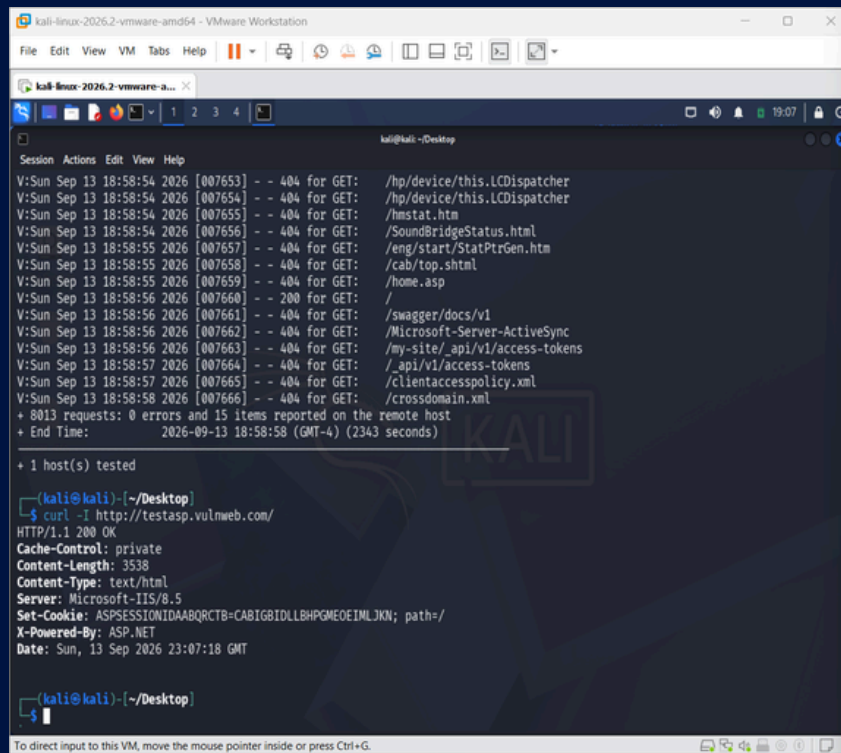
- **HTTP Response Header Verification:**

The HTTP response headers were manually examined using cURL: `curl -I http://testasp.vulnweb.com/`

The response returned:

- HTTP/1.1 200 OK
- Server: Microsoft-IIS/8.5
- Set-Cookie: ASPSESSIONIDAABQRCTB=...; path=
- X-Powered-By: ASP.NET

The response was reviewed for cookie security attributes and commonly recommended security headers.



```
kali@kali:~/Desktop
Session Actions Edit View Help
V:Sun Sep 13 18:58:54 2026 [007653] -- 404 for GET: /hp/device/this.LCDDispatcher
V:Sun Sep 13 18:58:54 2026 [007654] -- 404 for GET: /hp/device/this.LCDDispatcher
V:Sun Sep 13 18:58:54 2026 [007655] -- 404 for GET: /hmstat.htm
V:Sun Sep 13 18:58:54 2026 [007656] -- 404 for GET: /SoundBridgeStatus.html
V:Sun Sep 13 18:58:55 2026 [007657] -- 404 for GET: /eng/start/StatPtrGen.htm
V:Sun Sep 13 18:58:55 2026 [007658] -- 404 for GET: /cab/top.shtml
V:Sun Sep 13 18:58:55 2026 [007659] -- 404 for GET: /home.asp
V:Sun Sep 13 18:58:56 2026 [007660] -- 200 for GET: /
V:Sun Sep 13 18:58:56 2026 [007661] -- 404 for GET: /swagger/docs/v1
V:Sun Sep 13 18:58:56 2026 [007662] -- 404 for GET: /Microsoft-Server-ActiveSync
V:Sun Sep 13 18:58:56 2026 [007663] -- 404 for GET: /my-site/_api/v1/access-tokens
V:Sun Sep 13 18:58:57 2026 [007664] -- 404 for GET: /_api/v1/access-tokens
V:Sun Sep 13 18:58:57 2026 [007665] -- 404 for GET: /Clientaccesspolicy.xml
V:Sun Sep 13 18:58:58 2026 [007666] -- 404 for GET: /crossdomain.xml
+ 8013 requests: 0 errors and 15 items reported on the remote host
+ End Time: 2026-09-13 18:58:58 (GMT-4) (2343 seconds)

+ 1 host(s) tested

(kali@kali): ~/Desktop
$ curl -I http://testasp.vulnweb.com/
HTTP/1.1 200 OK
Cache-Control: private
Content-Length: 3538
Content-Type: text/html
Server: Microsoft-IIS/8.5
Set-Cookie: ASPSESSIONIDAABQRCTB=CABIGBIDLLBHPGMEOEIMLJKN; path=/
X-Powered-By: ASP.NET
Date: Sun, 13 Sep 2026 23:07:18 GMT

(kali@kali): ~/Desktop
$
```

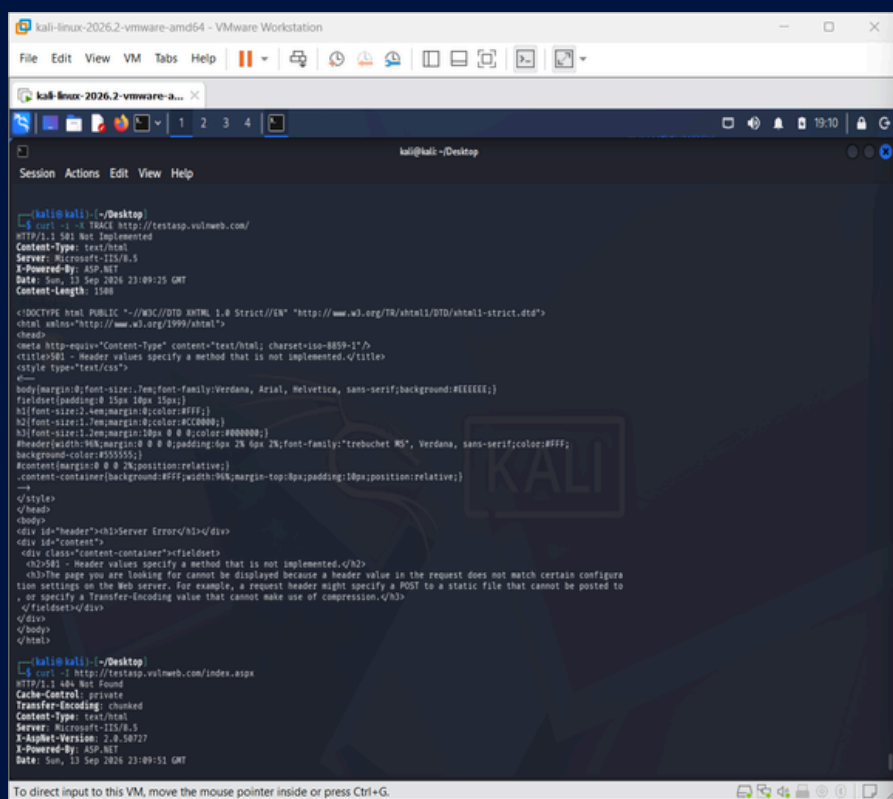
Figure 2 — HTTP Response Header Verification

ASP.NET Version Verification

- The /index.aspx endpoint was checked using: `curl -I http://testasp.vulnweb.com/index.aspx`

- The server returned: **HTTP/1.1 404 Not Found**
X-AspNet-Version: 2.0.50727
X-Powered-By: ASP.NET

Although the requested resource returned 404 Not Found, the response disclosed the ASP.NET framework version through the X-AspNet-Version header.



```
kali@kali:~/Desktop
└─$ curl -I -s -X TRACE http://testasp.vulnweb.com/
HTTP/1.1 501 Not Implemented
Content-Type: text/html
Server: Microsoft-IIS/8.5
X-Powered-By: ASP.NET
Date: Sun, 13 Sep 2026 23:09:25 GMT
Content-Length: 1580

<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">
<html xmlns="http://www.w3.org/1999/xhtml">
<head>
<meta http-equiv="Content-Type" content="text/html; charset=iso-8859-1"/>
<title>501 - Header values specify a method that is not implemented.</title>
<style type="text/css">
<!--
body{margin:0;font-size:1em;font-family:Verdana, Arial, Helvetica, sans-serif;background:#EEEEEE;}
fieldset{padding:0 15px 10px 15px;}
h1{font-size:2.4em;margin:0;color:#FFF;}
h2{font-size:1.2em;margin:0;color:#000000;}
h3{font-size:1.2em;margin:0px 0 0 0;color:#000000;}
#header{width:98%;margin:0 0 0 0;padding:0px 20px 20px 20px;font-family:"trebuchet MS", Verdana, sans-serif;color:#FFF;
background-color:#555555;}
#content{margin:0 0 0 0;position:relative;}
-->
</style>
</head>
<body>
<div id="header"><h1>Server Error</h1></div>
<div id="content">
<div class="content-container"><fieldset>
<h2>501 - Header values specify a method that is not implemented.</h2>
<h3>The page you are looking for cannot be displayed because a header value in the request does not match certain configura
tion settings on the Web server. For example, a request header might specify a POST to a static file that cannot be posted to
, or specify a Transfer-Encoding value that cannot make use of compression.</h3>
</fieldset></div>
</div>
</body>
</html>

kali@kali:~/Desktop
└─$ curl -I http://testasp.vulnweb.com/index.aspx
HTTP/1.1 404 Not Found
Cache-Control: private
Transfer-Encoding: chunked
Content-Type: text/html
Server: Microsoft-IIS/8.5
X-AspNet-Version: 2.0.50727
X-Powered-By: ASP.NET
Date: Sun, 13 Sep 2026 23:09:51 GMT
```

Figure 3 — ASP.NET Version Disclosure Verification

HTTP TRACE Method Verification

- The HTTP TRACE method was tested using::

```
curl -i -X TRACE http://testasp.vulnweb.com/
```

- The server returned:

HTTP/1.1 501 Not Implemented

Therefore, the Nikto observation regarding TRACE was not treated as a confirmed vulnerability.

ASP.NET Client Directory Verification

- The `/aspnet_client/` directory was checked using:

```
curl -I http://testasp.vulnweb.com/aspnet_client/
```

- The server returned:

HTTP/1.1 403 Forbidden

A follow-up request using `curl -I -L` also returned 403 Forbidden without a Location header. Therefore, the reported internal-IP disclosure was not treated as a confirmed finding.

Burp Suite Analysis

- **Login Page Request Analysis**

Burp Suite Community Edition was used to inspect the HTTP traffic generated by the authorized web application.

- **The following login page was accessed:**

<http://testasp.vulnweb.com/login.asp>

- **The request observed in Burp Suite was:**

GET /login.asp HTTP/1.1
Host: testasp.vulnweb.com

- **The server returned:**

HTTP/1.1 200 OK
Server: Microsoft-IIS/8.5
X-Powered-By: ASP.NET
Set-Cookie: ASPSESSIONIDAABQRCTB=...; path=/

The response confirmed that the login page was accessible over HTTP and that the server disclosed ASP.NET technology information.

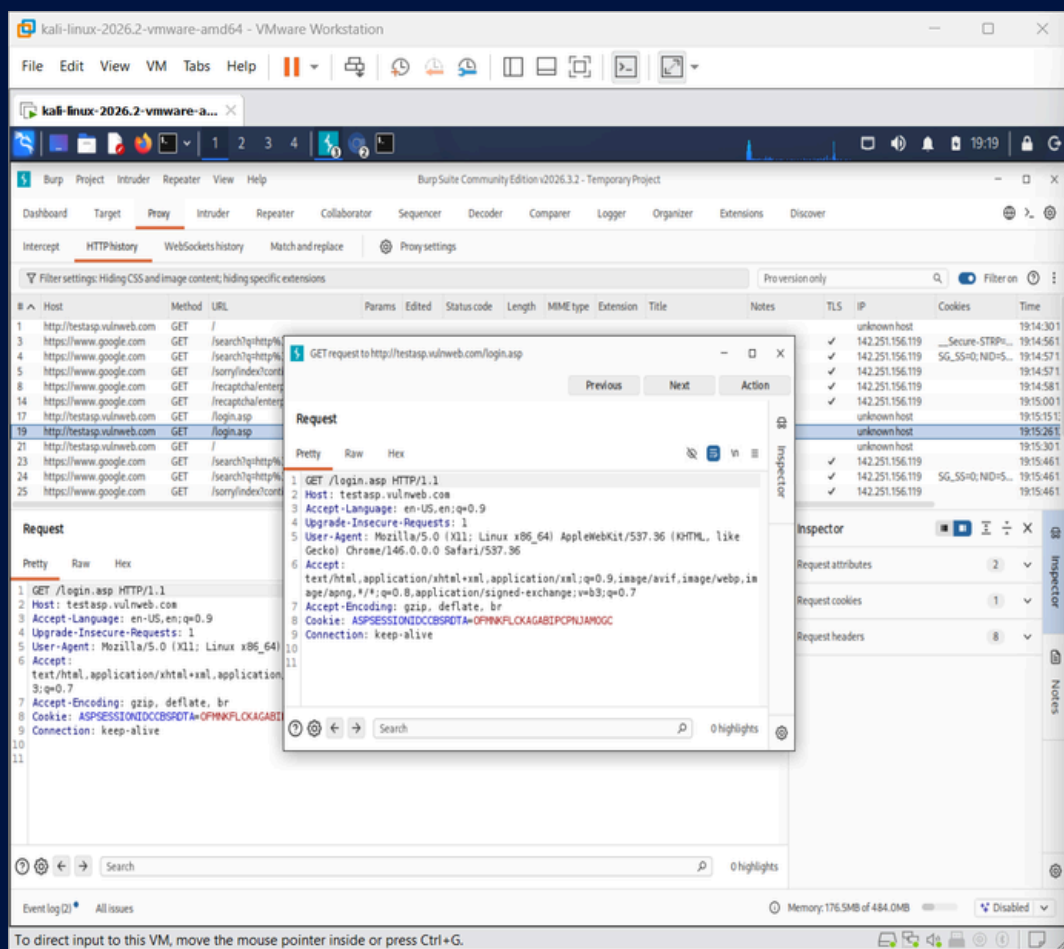


Figure 4 — Burp Suite Login Page Response

Login Form Analysis

The HTML response of the login page was inspected in Burp Suite.

- The login form uses the following fields:

Field	Parameter
Username	tfUName
Password	tfUPass

1. The form uses the POST method to process login information.
2. No real credentials were submitted during this assessment.

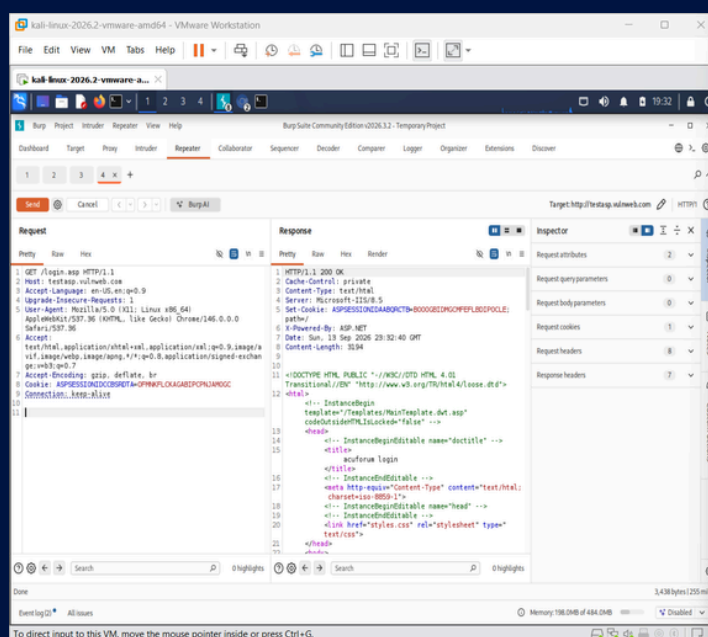


Figure 5 — Burp Suite Login Form Analysis

Cookie Security

Observation

- The Burp Suite response showed that the application sets an ASP.NET session cookie using:

Set-Cookie: ASPSESSIONIDAABQRCTB=...; path=/

1. The cookie does not include the **HttpOnly** attribute.
2. This observation was also independently verified using **cURL**.
3. The absence of **HttpOnly** means that client-side scripts may be able to access the session cookie if an applicable client-side vulnerability such as **XSS** exists.

Security Findings

Finding 1 — Session Cookie Missing HttpOnly

- **Severity:** Low
- **Description:** The ASP.NET session cookie is set without the HttpOnly attribute.
- **Evidence:** Set-Cookie: ASPSESSIONIDAABQRCTB=...; path=/

- **Impact:**

Without HttpOnly, client-side JavaScript may be able to access the session cookie. If an XSS vulnerability exists, this could increase the risk of session-cookie exposure.

- **Recommendation:**

Configure session cookies with the HttpOnly attribute and use appropriate cookie security settings.

Finding 2 — Missing HTTP Security Headers

- **Severity: Low / Informational**

The HTTP response did not include several commonly recommended security headers, including:

1. **X-Content-Type-Options**
2. **Content-Security-Policy**
3. **Referrer-Policy**
4. **Permissions-Policy**
5. **Strict-Transport-Security**

- **Impact:**

The absence of these headers reduces available browser-side security protections and can make the application more exposed to certain classes of web attacks.

- **Recommendation:**

Configure appropriate security headers according to the application's requirements. HTTPS should also be used so that HSTS can be applied where appropriate.

Finding 3 — ASP.NET Version Disclosure

- **Severity: Low / Informational**

- **The /index.aspx response disclosed:
X-AspNet-Version: 2.0.50727**

- **Impact:**

The disclosed framework version provides technology fingerprinting information that could assist an attacker during reconnaissance.

- **Recommendation:**

Suppress unnecessary framework version information from HTTP response headers.

- **Evidence:**

P4_ASPNET_Version_Disclosure.png

Finding 4 — ASP.NET Technology Disclosure

- **Severity: Informational**
- **The application discloses its technology through:
X-Powered-By: ASP.NET**
- **Impact:**
This provides additional information about the underlying web application technology.
- **Recommendation:**
Remove unnecessary technology-identifying headers where practical.

Result

No.	Finding	Severity	Verification
1	Session cookie missing HttpOnly	Low	✓ Confirmed with cURL and Burp
2	Missing HTTP security headers	Low / Informational	✓ Confirmed with cURL
3	ASP.NET version disclosure	Low / Informational	✓ Confirmed with cURL
4	ASP.NET technology disclosure	Informational	✓ Confirmed with cURL
5	HTTP TRACE	—	✗ Not confirmed; server returned 501
6	Internal IP disclosure	—	✗ Not confirmed; endpoint returned 403

- **Key observations:**

The assessment demonstrated that the application exposes certain server and framework information through HTTP response headers. The session cookie was also found to lack the HttpOnly attribute.

Burp Suite provided additional visibility into the application's login page and confirmed the presence of the username and password form parameters without requiring submission of real credentials.

Recommendations

The following security improvements are recommended:

- **Configure session cookies with the HttpOnly attribute.**
- **Review and implement appropriate HTTP security headers such as:**
 - 1. Content-Security-Policy**
 - 2. X-Content-Type-Options**
 - 3. Referrer-Policy**
 - 4. Permissions-Policy**
- **Suppress unnecessary ASP.NET version and technology disclosure headers.**
- **Serve authentication-related pages and forms exclusively over HTTPS.**
- **Periodically perform security configuration reviews and vulnerability assessments.**
- **Validate automated scanner findings manually before classifying them as confirmed vulnerabilities.**

Conclusion

The Basic Web Vulnerability Assessment successfully demonstrated the use of Nikto, cURL, and Burp Suite to assess an intentionally vulnerable web application.

The assessment identified several low-severity security weaknesses, including a session cookie without the HttpOnly attribute, missing HTTP security headers, and disclosure of ASP.NET technology and version information.

Automated findings were manually validated where possible. Findings that could not be reproduced during manual verification were not classified as confirmed vulnerabilities. This helped ensure that the assessment results remained evidence-based and accurate.

Overall, the project provided practical experience in web reconnaissance, HTTP response analysis, cookie security, security-header assessment, technology fingerprinting, and basic web application testing.